Доверие и безопасность: честные работодатели и защита кандидатов

Документ описывает, как платформа защищается от фиктивных вакансий и недобросовестных работодателей и что в этой части **реализовано**, а что пока **концепция**. Ответы организаторов: подтверждение компании может быть добровольной меткой и не должно блокировать основной сценарий; защита от фиктивных вакансий выходит за рамки MVP и засчитывается как концепция. Поэтому всё ниже построено на дешёвых сигналах, а решение всегда принимает человек.

Все числа, пороги и подписи — в `config/trust.yaml` и `config/contact.yaml` (в коде их нет).

1. Принципы

1. **Метка добровольная.** «Проверенная компания» никогда не требуется для приглашений, вакансий и квоты. Отсутствие метки — не вывод о компании и не штраф.
2. **Сигналы подсказывают, не наказывают.** Автоматически меняется только квота (мягко, обратимо); метку снимает и жалобы разбирает методист или администратор.
3. **Кандидат защищён.** Жалоба анонимна для компании: компания о ней не уведомляется и не видит автора.
4. **Всё объяснимо.** Работодатель видит, какие проверки не прошли, а причина сниженной квоты написана словами в его профиле.

2. Метка «Проверенная компания» (реализовано)

Компания вводит ИНН и ОГРН (`POST /api/companies/me/verification` , экран «Профиль компании»). Проверки (`app/trust/verification.py`):

Проверка	Как
Контрольная сумма ИНН (10 цифр — юрлицо, 12 — ИП)	Алгоритм ФНС: взвешенная сумма по модулю 11 и 10 (`app/trust/checksums.py`)
Контрольная сумма ОГРН (13 цифр) / ОГРНИП (15)	Остаток от деления первых 12 (14) цифр на 11 (13), последняя цифра
Компания найдена в реестре и ИНН с ОГРН относятся к одной записи	Учебный реестр ЕГРЮЛ
Статус «действующая»	Поле реестра
Название совпадает	Слова названия профиля против названия в реестре без «ООО/АО/ИП» и кавычек, порог `name_match_min_ratio`
ИНН не занят другой компанией	Один ИНН — одна проверенная компания (защита от выдачи себя за другого)
Домен корпоративной почты совпадает с доменом из реестра	Личные домены (gmail и т. п.) уровень «домен» не дают

Уровни: **«Реквизиты проверены»** (все проверки, кроме домена) и **«Домен подтверждён»** (плюс домен). Кандидат видит метку в приглашении, в списке и карточке вакансии и в «так видит кандидат»; реквизиты и детали проверок ему не показываются.

Реестр в MVP **учебный** (`app/trust/data/mock_egrul.json` , вымышленные компании); интерфейс `EgrulProvider` — точка подключения реального сервиса ФНС без правок остального кода. Переименование компании пересчитывает метку (нельзя получить метку и сменить название). Компания может сама убрать метку (`DELETE`). Методист или администратор отзывает метку с причиной (`POST`

`/api/admin/trust/companies/{id}/revoke`); пока отзыв не снят, подать реквизиты заново нельзя, но остальная работа компании не ограничена.

3. Жалобы кандидатов и модерация (реализовано)

- **Где пожаловаться:** на приглашение (`POST /api/invitations/{id}/report`) и на вакансию (`POST /api/vacancies/{id}/report`). Причины (`config/contact.yaml → reasons.complaint`): фиктивная вакансия, просят деньги или документы, спам, условия не соответствуют действительности, **сбор резюме без вакансии**, **зарплата не та**, **не отвечают после «да»**, другое. Одна жалоба от кандидата на объект.
- **Очередь модерации:** методист или администратор видит жалобы (`GET /api/admin/trust/complaints`, экран «Жалобы» в лаборатории), с числом разных кандидатов, пожаловавшихся на ту же компанию, и текущей меткой. Решение: **подтверждена** или **отклонена** (с заметкой).
- **Последствия:**
  - от **трёх разных кандидатов** за 90 дней открытых или подтверждённых жалоб — квота приглашений компании ×0,5 (`complaints.quota_threshold`, `quota_factor`); причина «жалобы кандидатов» показана компании в профиле. Отклонённые жалобы не считаются, поэтому квота возвращается сразу после разбора;
  - подтверждённая жалоба по серьёзной причине (фиктивная вакансия, просьба денег, сбор резюме) **снимает метку** «Проверенная компания»;
  - жалоба влияет на квоту вместе с надёжностью R: берётся меньший множитель, а не произведение.
- Старые жалобы (до миграции `0011_trust_minors`) перенесены в очередь автоматически.

4. Что уже защищало платформу (используется как есть)

Механизм	Что делает
Обязательная вилка и правила (`config/contact.yaml → salary`)	Нижняя граница не меньше минимума, `to/from` > 1,6 — предупреждение, > 2,0 — блокировка: вилка «от 10 до 1 000 000» невозможна
Условия неизменяемы	Каждая версия условий приглашения хранится со `sha256`; кандидат отвечает на конкретные условия, подмена после ответа видна
Квоты	60 новых приглашений за 7 дней на домен (на аккаунт для личной почты), 20 активных на бриф, лимит кандидата в неделю: массовая рассылка в пустоту не окупается, истёкшие без просмотра возвращают слот
Стоп-слова и ссылки	Плашка «Требует осторожности» у кандидата для просьб денег, документов, ссылок-сокращателей и контактов в тексте приглашения (`app/contact/antifraud.py`)
Надёжность R	Формула из журнала событий (ответ в срок, контакт после «да», «условия совпали»); расхождение условий у двух разных кандидатов за 90 дней — бейдж «есть расхождения условий» и квота ×0,5
«Условия совпали?» через 10 дней после «да»	Кандидат сообщает «зарплата ниже» или «вакансии нет» — это событие надёжности
Контакты кандидата	Раскрываются только после взаимного «да» и отдельного согласия: «сбор данных» без согласия невозможен

Сравнение зарплаты приглашения с вилкой брифа раньше не проверялось: работодатель мог указать в приглашении любую допустимую вилку. Теперь это автосигнал (п. 5), а не блокировка: у честного работодателя бриф и приглашение могут расходиться (новое решение по бюджету).

5. Автосигналы для модератора (реализовано)

`GET /api/admin/trust/flags`, вкладка «Автосигналы». Считаются на лету (`app/trust/flags.py`, пороги в `config/trust.yaml → flags`), ничего не блокируют:

Сигнал	Условие
Много приглашений, ни одного принятого	20 и более приглашений за 30 дней и ни одного «да»
Вакансия висит без откликов	Опубликована более 30 дней назад, откликов и принятых приглашений нет
Зарплата в приглашении ниже брифа	Нижняя граница первой версии условий ниже 0,9 от нижней границы брифа (на одном базисе «на руки / до НДФЛ»), не менее двух приглашений
Расхождение условий	Не менее двух сообщений кандидатов «условия не совпали» за окно (журнал надёжности R)

6. Что реализовано и что в плане

Область	Реализовано	В плане (после MVP)
Проверка компании	Контрольные суммы ИНН/ОГРН, учебный реестр, уровни метки, отзыв, пересчёт при переименовании	Реальный ЕГРЮЛ/ФНС-API; подтверждение права подписи (доверенность, выписка); проверка принадлежности домена (DNS-запись или письмо на `admin@домен`)
Жалобы	Приглашения и вакансии, очередь, решения, влияние на квоту и метку	Апелляция компании; обратная связь заявителю о результате; классификатор по тексту жалоб
Автосигналы	4 эвристики, подсказки модератору	Сигналы по скорости рассылки, повторяющимся текстам вакансий, перепродаже контактов; ранжирование очереди по риску
Фиктивные вакансии	Метка, квоты, вилка, стоп-слова, жалобы, висящие вакансии	Верификация вакансии через ATS (вакансия существует в системе найма — см. ATS_INTEGRATION.md); срок жизни вакансии с подтверждением актуальности; публичный «светофор» репутации
Наказание	Мягкое снижение квоты, снятие метки	Блокировка аккаунта по решению модератора с обжалованием; чёрный список реквизитов

7. Ограничения (честно)

- Учебный реестр не проверяет реальные компании: метка в демо демонстрирует механику и интерфейс.
- Совпадение домена не доказывает, что сотрудник вправе действовать от имени компании.
- Квота по жалобам — защита от массовой рассылки, но не от одного точечного обмана; для него нужны разбор человеком и санкции вне MVP.
- Порог «три разных кандидата» не защищает от сговора жалобщиков: поэтому жалобы только снижают квоту, а решающее слово — у модератора.

Модуль несовершеннолетних (согласие законного представителя) описан в SECURITY.md, п. 1.4.